User Charter

Introduction

At OpenPharma, protecting information is essential to our success and our commitment to patient safety. Our goal is to ensure confidentiality, integrity, and availability of information by following clear guidelines, roles, and responsibilities.

Our global security policy is the foundation of our approach. It outlines the key principles for all related policies, procedures, and guidelines and is aligned with OpenPharma's goals. Reviewed and approved by top management every year, this policy ensures we stay updated and effective in managing security.

We share these principles with our employees through regular training and communication, making sure everyone understands their role in keeping information secure. Our security policies follow ISO 27001/2 standards and best practices, and these requirements are regularly monitored to ensure compliance.

At OpenPharma, we are committed to protecting our intellectual property and patient information while preventing security risks. Our User Charter, based on the Global Security Policy, helps our team safeguard resources, reduce risks, and avoid incidents, keeping us ahead in the industry and earning the trust of all our stakeholders.

Principles

Confidentiality

Protecting the confidentiality of our information is paramount. Unauthorized access to sensitive data could lead to financial loss, legal consequences, or damage to our reputation. By restricting access to authorized individuals only, we ensure that our company's sensitive information remains secure and protected from unauthorized disclosure.

Integrity

We ensure the integrity of our information by implementing measures to prevent unauthorized modifications. Unauthorized changes to data could lead to misinformation, loss of trust from customers or stakeholders, and financial harm. Maintaining data integrity ensures that our information remains accurate, reliable, and trustworthy.

Availability

Our information systems and resources must be available and accessible to you when needed, per our business requirements. Downtime or disruptions in system availability could disrupt business operations, lead to financial losses, or impact on our ability to serve customers. By ensuring availability, we maintain business continuity and minimize the risk of disruptions.

Open Pharma

Objective

The User Charter is designed to involve staff in following the cybersecurity protocols and promoting a sense of security awareness while making sure everyone follows the company's Global Security Policy carefully.

Scope

The charter establishes guidelines for all employees to protect organizational assets, covering data, systems, and physical security while defining their responsibilities in access control, cybersecurity practices, and compliance. Its scope is limited to activities and resources within the organization, excluding personal activities or assets outside its jurisdiction.

User's Rights and Duties

1. **Topic #1: Information Security Awareness**
   - All employees must comply with the organization's information security policies and procedures.
   - Be aware of possible threats and understand the need to protect sensitive data.
   - Participate in all mandatory training sessions.
   - Follow the company's cybersecurity best practices while working.
   - Identify and address potential risks in a timely manner.
   - Report any suspicious activity or security concerns to the relevant officials/department.
   - These measures ensure that organizational resources are protected, preserving confidentiality, integrity, and availability of information.

2. **Topic #2: Access Control**
   - Follow all organizational access control policies to prevent information exposure.
   - Sensitive access will be granted based on employees' positions and business needs.
   - Do not attempt to access systems or data beyond your authorization.
   - Never share your login details, even with colleagues.
   - Always use your personal account and avoid shared accounts unless explicitly permitted.
   - For additional access, submit a request through the proper channels.
   - Report any unauthorized or illegal access attempts immediately.

3. **Topic #3: Phishing Awareness**
   - Be careful of phishing, one of the most widespread cybersecurity risks.
   - Do not click on unknown links or open unknown attachments in emails, messages, or pop-ups.
   - Always check the sender's identity, especially when receiving unsolicited messages asking for sensitive data or planning to perform financial operations.
   - Report any phishing attempts to the IT helpdesk or the security team.

- Engage in phishing awareness training frequently to stay informed about the latest attacker strategies and know how to respond to threats.

4. **Topic #4: Password Management**
   - Use different passwords for different accounts to prevent the risk of multiple accounts being compromised.
   - Create complex passwords using a mix of lowercase and uppercase letters, numbers, and symbols.
   - Avoid using easily guessable information like your name or date of birth.
   - Never reuse the same password across multiple websites or accounts.
   - Ensure your passwords are secure and unique for both personal and organizational use.
   - Recommendation is to utilize organization-approved password management tools to store your credentials safely.
   - Changing the passwords at least once in 45 days is recommended to maintain security.
   - Report any signs of intrusion or suspicious activity immediately.
   - Adhere to the organization's policies when setting or changing your passwords.

5. **Topic #5: Secure Device Usage**
   - It is each employee's responsibility to ensure that all devices used for work, whether personal or organizational, are secure.
   - Basic precautions include installing and updating antivirus software, operating systems, and applications to avoid vulnerabilities.
   - Employees should secure their devices with strong passcodes or biometric locks.
   - Enable remote wipe features on mobile devices in case they are lost or stolen.
   - Avoid using public Wi-Fi connections for work-related activities.
   - Ensure that all devices meet the organization's security standards.

6. **Topic #6: Physical Security**

   - **Safeguard Physical Property:**

     - Lock your computer screen every time you walk away from it.
     - Lock up all drawers or cabinets that may contain sensitive information.
     - Be cautious about people who are not supposed to be in certain areas and report any contact that looks suspicious.
     - Ensure that confidential information, such as documents, is disposed of properly, for instance, by shredding or any other secure means.
     - Never forget to wear your identification tag when in the office.
     - Ensure that all entrances and exits, such as doors and windows, are locked when you are leaving the premises.
   - **Tailgating:**

  - Do not allow unauthorized individuals to follow you into secure areas without proper credentials.
  - Be vigilant and ensure that the door closes securely behind you to prevent unauthorized access.

- **Piggybacking:**
  - Do not hold the door open for others unless you are certain they are authorized to enter.
  - Verify the identity of individuals who ask to follow you through secure entrances.

By following these guidelines, you help protect both physical property and sensitive information, ensuring the safety and security of the organization.

Checks and Consequences/penalties

Checks:

- Periodic audits will be conducted to assess compliance with security protocols and the user charter.
- Audits will include checks on:
  - Access control policies
  - Password management practices.
  - Device security measures.
  - Physical security protocols.
- Security training sessions will be evaluated to ensure:
  - All employees are up to date with the latest cybersecurity threats.
  - Best practices are consistently followed.

Consequences/penalties:

For the company:

- **Data Breach**: A rule violation could lead to unauthorized access or data leakage, resulting in financial loss, legal liabilities, and reputational damage.
- **Operational Disruption**: Non-compliance could compromise system integrity, causing downtime or business continuity issues.
- **Regulatory Penalties**: Breaches of compliance policies may result in fines or sanctions under applicable laws.

For the user:

- **Disciplinary Action**: Employees may face warnings, suspension, or termination based on the severity of the breach.
- **Legal Accountability**: Deliberate or negligent breaches could result in personal liability, including lawsuits or criminal charges.

- **Loss of Trust**: Violations may damage the employee's credibility and future opportunities within or outside the organization.

Additional Information

The security team is committed to helping users comply with the organization's security charter by providing continuous support and resources. This includes:

- **Training and Education:** Regular training sessions and educational materials to keep users informed about the latest security practices and threats.
- **Best Practices Guidance:** Clear guidelines on best practices for securing passwords, identifying phishing attempts, and safeguarding devices.
- **Security Tools:** Access to approved security tools, such as password managers and antivirus software, to enhance overall protection.
- **Incident Response:** Dedicated support for incident response, ensuring quick and effective action in case of security breaches or suspicious activities.
- **Open Communication Channels:** Availability of open communication channels for users to report security concerns, seek advice, or ask questions.

By leveraging these resources and support, users can effectively maintain security standards and protect organizational assets.

Glossary:

Malware: Malicious software designed to harm or exploit devices, networks, or systems.

Phishing: A deceptive attempt to steal sensitive information through fraudulent emails or messages.

MFA (Multi-Factor Authentication): A security measure that can be bypassed if improperly configured or implemented.

Tailgating: Unauthorized access where an intruder follows someone with legitimate access into a secure area.

Piggybacking: Gaining unauthorized access by persuading someone to allow entry, often under false pretenses.